



Figure 1: A stakeholder-led security approach

the tools and training needed for execution. Understanding these layers helps organisations lay their assets in a logical flow that governs the next layer of actions.

Layer 1: Building a vision to define how things need to be done

The vision for organisational security forms the foundation of strategy design. It should articulate how the entire organisation approaches security to safeguard business assets, resources, functions/units, and stakeholders.

Who are the stakeholders?

The stakeholders at this layer are executives, CXOs and leaders who define organisational-level priorities.

What are the objectives?

The objectives of this layer are to define security core principles, establish a global and regional security vision, and outline compliance-related security awareness plans.

What are the intended outcomes?

Involving leaders early in security strategy design helps avoid the pitfalls of isolated decision-making. It helps leaders devise policies and garner community support at the topmost level, cultivating a security-focused

culture and fostering shared ownership of security objectives. This empowers business units to embed security into their work, making it an inherent part of everyday activities and creating a sense of collective responsibility for security goals.

Layer 2: Making the vision a reality by outlining the business unit security journey

The business unit security journey acknowledges the unique security needs of each business unit, guiding it to effectively implement the organisational security vision.

Who are the stakeholders?

Here, stakeholders feature leaders from product lines, accounts, or functional departments who hold accountability for business units.

What are the objectives?

The objectives at this layer are to define business unit-level risk management frameworks as well as business continuity plans and ensure health monitoring. An additional aim is to provide resources and direction on security best practices for projects under each unit.

What are the intended outcomes?

This layer ensures that security strategies are not imposed in a top-down manner and that ground-level

practicalities are also considered. Risk assessments and plans should align organisational security initiatives with the needs and risk profiles of individual business units. The feedback loops that are initiated by the ground-level implementation should help refine the overall security vision and goals. This will ensure a more practical and effective approach to security.

Layer 3: Bridging the strategy-execution gap with effective project engineering practices

The project engineering practices layer bridges the gap between high-level security objectives and the hands-on work done by development and project teams. It ensures that the strategy properly informs every part of the engineering machine.

Who are the stakeholders?

The stakeholders include team leads, security analysts, and project communities who integrate security into every stage of the project life cycle.

What are the objectives?

We want to define the practice model, implement technical guidelines and architectural reviews, and ensure training for each team member. Additionally, we need to set up the right metrics to track and recalibrate the security posture regularly.

What are the intended outcomes?

This layer applies the organisational security vision to the practice of software engineering. Metrics such as vulnerability density, mean time to detect (MTTD) and mean time to remediate (MTTR) enable feedback on the effectiveness of project engineering practices, and help to further refine the overall security strategy and promote a proactive approach to security. These then act as guideposts for engineering teams to make informed security decisions and follow best practices.